CYBERSECURITY INTERNSHIP — PRACTICAL LAB REPORT

Day 04: Vishing & Smishing Social Engineering Simulation

Intern Name:	Md Peer Siddiqui	**Program / Track:**	Alpha 2 — Cybersecurity Track
Issuing Body:	Sqrock IT Solution	**Date of Execution:**	October 23, 2026
Tool Developed:	PEER'S Vish & Smish Simulator v1.0	**GitHub Repository:**	github.com/MdPeerSiddiqui/PEER-S-Vish-Smish-Simulator

1. Objective & Operational Scope

To research the conversational and psychological mechanics of voice phishing (vishing) and SMS phishing (smishing) attacks, and develop an enterprise-grade command-line simulation suite in Python. The simulator deconstructs 10 comprehensive social engineering industry vectors across a 5-phase conversational attack lifecycle, evaluates psychological trigger intensity across 5 manipulation levers, calculates GSM-7 character segmentation for mobile smishing lures, and provides actionable telecom defensive countermeasures.

2. Tools and Technical Environment

- **Operating Environment:** Kali Linux 2026.2 (64-bit VirtualBox VM) / Windows 11 Enterprise
- **Core Platform:** Python 3.11.9 / 3.14.0 (Standard Libraries: json, argparse, os, sys, unittest)
- **Terminal UI & PDF Engines:** colorama v0.4.6 (ANSI terminal styling), reportlab v5.1.0 (PDF Engine)
- **Scenario Database:** scenarios.json (10 comprehensive industry vectors with multi-phase dialogue and objection handling)

3. The 5-Phase Conversational Vishing Attack Lifecycle

Unlike automated email phishing, telephone-based vishing exploits synchronous human conversation to enforce rapid cognitive compliance. Every simulation generated by the tool models the standardized 5-phase threat progression:

Attack Phase	Attacker Objective & Psychological Tactics	Forensic Indicator
Phase 1: Pretext Intro	Establish immediate authoritative persona (e.g. IT Helpdesk, Bank Fraud Officer, Government Agent) using corporate terminology and caller ID spoofing.	P-Asserted-Identity SIP spoofing.
Phase 2: The Hook	Introduce a fabricated time-sensitive emergency (e.g. account suspension in 15 mins, $2,845 foreign wire, immediate power disconnect) to induce panic.	Urgency & Fear manipulation.
Phase 3: The Ask	Extract sensitive credentials, multi-factor authentication (MFA) push tokens, banking routing numbers, or coerce installation of remote-access tools.	Credential harvesting / 2FA token relay.
Phase 4: Objection Handling	Neutralize victim skepticism using pre-scripted psychological counters (e.g., citing maintenance tickets, warning of long queue delays, escalating consequences).	Overcoming security policy resistance.
Phase 5: Exit Strategy	Provide false reassurance of ticket resolution and delayed email receipts to prevent the victim from realizing compromise or alerting the real SOC immediately.	Compromise masking & delay.

4. Comprehensive 10-Category Social Engineering Attack Matrix

To ensure comprehensive threat modeling beyond basic IT and banking pretexts, the engine incorporates 10 distinct real-world attack scenarios, evaluating psychological manipulation intensity across all 5 levers:

1	Enterprise IT	Global VPN Migration & MFA Re-Auth	`+1 (800) 555-0199`	80/100	MFA Push Token Relay via Active Directory lock threat
2	Banking & Finance	Unauthorized Wire & Debit Card Lock	`+1 (888) 456-7890`	83/100	Fund transfer cancellation OTP theft ($2,845 lure)
3	Government & Tax	Federal Tax Deficit Audit Summons	`+1 (202) 555-0143`	75/100	SSN & checking account harvesting via warrant threat
4	Logistics / Courier	Undelivered Express Parcel Re-Route	`+1 (800) 463-3339`	69/100	Full credit card extraction via $2.45 redelivery fee
5	Corporate HR	Mandatory Direct Deposit Re-Verification	`+1 (800) 555-0188`	80/100	ABA routing & bank account redirect before payroll cutoff
6	Healthcare / Medical	Prescription Medication Hold & Copay	`+1 (877) 555-0177`	83/100	Patient PII & card theft via critical medication delay
7	Executive Whaling	Confidential Board M&A; Settlement	`+1 (212) 555-0100`	84/100	Urgent $48,500 wire authorization under CEO pressure
8	Telecom Carrier	SIM Swap & Cellular Line Deactivation	`+1 (800) 937-8997`	85/100	Carrier transfer PIN theft to complete SIM port hijack
9	E-Commerce Retail	High-Value Unauthorized Order Refund	`+1 (888) 280-4331`	79/100	Quarantined order dispute to harvest login & CVV
10	Utility Services	Immediate Power Disconnect Notice	`+1 (800) 555-0155`	80/100	Immediate emergency voucher payment under cutoff threat

5. Psychological Manipulation Index (The Trigger Radar)

Social engineering exploits inherent human heuristics: reciprocity, social proof, commitment, liking, authority, and scarcity (Cialdini's principles). The simulator evaluates each pretext across 5 weighted vectors:

• **Urgency (25% Weight):** Artificial time windows (e.g. 15-minute lockout) designed to trigger cognitive overload and prevent logical consultation.
• **Fear & Intimidation (25% Weight):** Threats of arrest, permanent salary loss, or immediate power disconnection that induce freeze-or-comply instincts.
• **Authority (20% Weight):** Exploitation of formal hierarchy (e.g. Revenue Officer, Executive VP, Security Analyst) where disobedience implies insubordination.
• **Scarcity (15% Weight):** Perceived loss of unique opportunities (e.g. priority express parcel destroyed, M&A; deal collapse).
• **Sympathy / Helpfulness (15% Weight):** Posing as a cooperative ally striving to 'protect' the victim from hostile third-party hackers.

6. Smishing Technical Forensics & GSM-7 Payload Analysis

Short Message Service (SMS) represents a high-conversion delivery mechanism due to an estimated 98% open rate and 90-second average read time. The simulation engine audits mobile payload constraints:

SMS Technical Parameter	Standard Specification	Smishing Attack Weaponization
GSM-7 Encoding Limit	160 characters per single transmission segment.	Attackers craft concise lures under 160 chars to minimize carrier filtering and ensure clean single-message delivery.
Alphanumeric Sender ID	Up to 11 alphanumeric characters (e.g. CORP-IT-ALERT).	Spoofed via international bulk SMS aggregators to overwrite caller telephone numbers with official corporate tags.
URL Shortening & Cloaking	Redirection services (bit.ly, tinyurl, custom domains).	Conceals credential harvesting landing pages and bypasses mobile browser reputation checks.

7. Telecom Anti-Spoofing Architecture: STIR/SHAKEN Framework

To mitigate caller ID spoofing, modern telecommunications carriers deploy the **STIR/SHAKEN** suite (*Secure Telephony Identity Revisited / Signature-based Handling of Asserted information using toKENs*):
• **Full Attestation (Level A):** The originating service provider knows the customer and verifies their lawful right to use the specific telephone number.
• **Partial Attestation (Level B):** The carrier recognizes the originating customer but cannot cryptographically verify their right to assert the caller ID.
• **Gateway Attestation (Level C):** The call originated from an untrusted international gateway with no validation of identity or origin.
Defensive Limitation: STIR/SHAKEN verifies the telephone number ownership, but *cannot* verify whether the individual speaking is a legitimate employee or a malicious actor using an authentic compromised PBX trunk.

8. Enterprise Out-of-Band (OOB) Verification Playbook

Operational Step	Mandatory SOC & Employee Verification Protocol
1. Immediate Disconnect	**Never comply on inbound calls:** Politely inform the caller you will verify the ticket independently, and immediately terminate the telephone call.
2. Independent Lookup	**Zero-Trust Directory Lookup:** Obtain the official contact number from a pre-authenticated physical employee badge, corporate intranet, or physical bank card.
3. Out-of-Band Call	**Originating Call Verification:** Place an outbound call to the verified internal extension to determine if a legitimate IT ticket or fraud case actually exists.
4. FIDO2 Enforcement	**Hardware Token Architecture:** Replace voice-relayable 6-digit SMS OTPs with FIDO2 / WebAuthn hardware tokens (YubiKeys), neutralizing vishing token theft.

9. Forensic Code Verification & Benchmark Audit Results

The software architecture was validated using Python's built-in unittest framework (tests/test_vish_smish.py). A 9-point unit test suite verified scenario database completeness, 5-phase dialogue presence, GSM character segmentation, and mathematical scoring boundaries across all 10 social engineering industry sectors:

Total Scenarios Audited	10 Comprehensive Industry Categories (IT, Bank, Gov, Courier, HR, Medical, CEO, Telecom, Retail, Utility)	**100% VALIDATED**
Dialogue Progression	5 Phases present per scenario (Intro, Hook, The Ask, Pre-Scripted Objections, Exit)	**100% VALIDATED**
Pre-Scripted Objections	20 Total Objections & Realistic Attacker Counter-Pretexts	**100% VALIDATED**
GSM-7 Character Analysis	100% of smishing lures audited for 160-character single SMS compatibility	**100% VALIDATED**
Unit Test Suite	9/9 Automated Unit Tests Passed (Execution time: 0.003 seconds)	**PASSED (9/9)**

10. Ethical Compliance & Authorization Boundaries

All simulation scripts and smishing lures were developed strictly for defensive education, red team security assessments, and security awareness training under authorized internship terms at Sqrock IT Solution. Live transmission of deceptive voice calls or unsolicited SMS messages over public telecommunications networks without prior explicit authorization is illegal under the Telephone Consumer Protection Act (47 U.S.C. § 227), Truth in Caller ID Act of 2009, and Section 43/66 of the Indian Information Technology Act, 2000.

11. Internship Practical Sign-Off & Conclusion

Day 04 practical training provided critical insight into the convergence of psychological manipulation and telecommunications exploitation. By modeling attack progressions across IT, banking, regulatory, healthcare, and telecom vectors, this project demonstrated that conversational vishing represents a primary bypass mechanism against technical email filters. Mitigating voice-driven social engineering requires replacing verbal credentials with cryptographic FIDO2 hardware tokens, enforcing mandatory out-of-band verification workflows, and implementing telecom STIR/SHAKEN attestation inspection.